



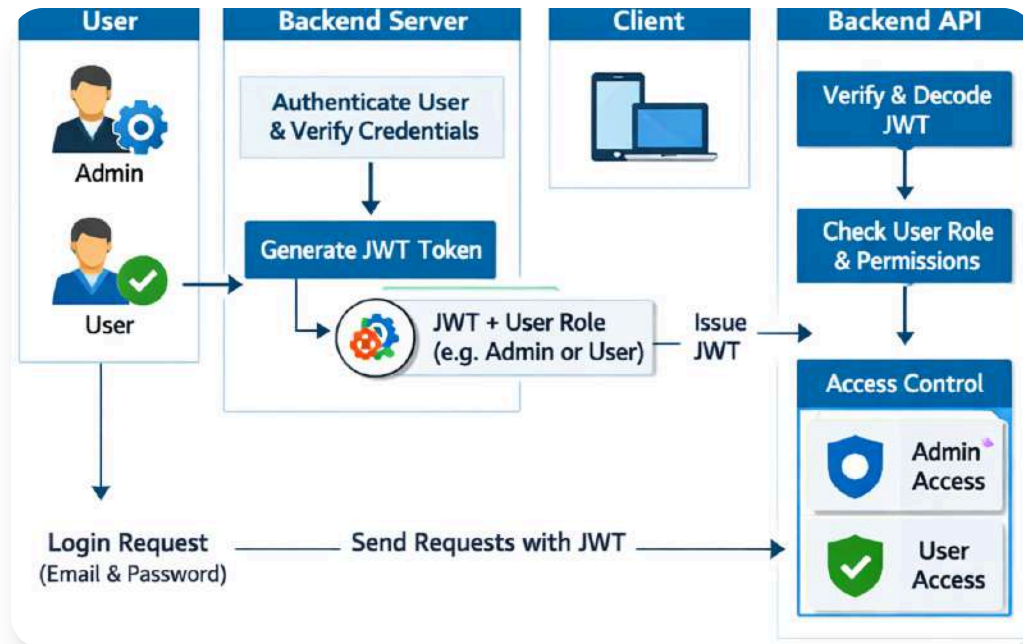
Golang Gin Backend Pertemuan 13

Membahas register, login, JWT, role admin dan user, logout dengan blacklist token, serta endpoint auth me untuk akses API aman.



Juara Coding

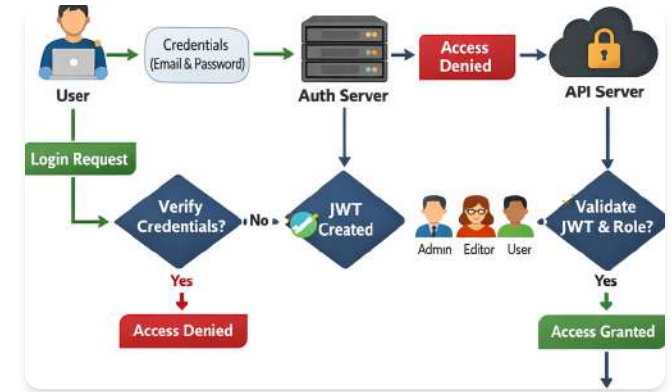
June 2026



Tujuan Pembelajaran

Peserta mampu membangun autentikasi backend Gin: registrasi, login JWT, otorisasi role, logout aman, dan endpoint **auth me**.

Alur Auth Backend



01 Register dan Login

Pengguna mendaftar untuk membuat akun, lalu login untuk memperoleh token JWT sebagai kredensial akses.

03 Verifikasi, Role, dan Logout

Middleware memverifikasi token, membaca role user, memberi akses sesuai hak, lalu logout menaruh token ke blacklist.

02 Akses Endpoint Terproteksi

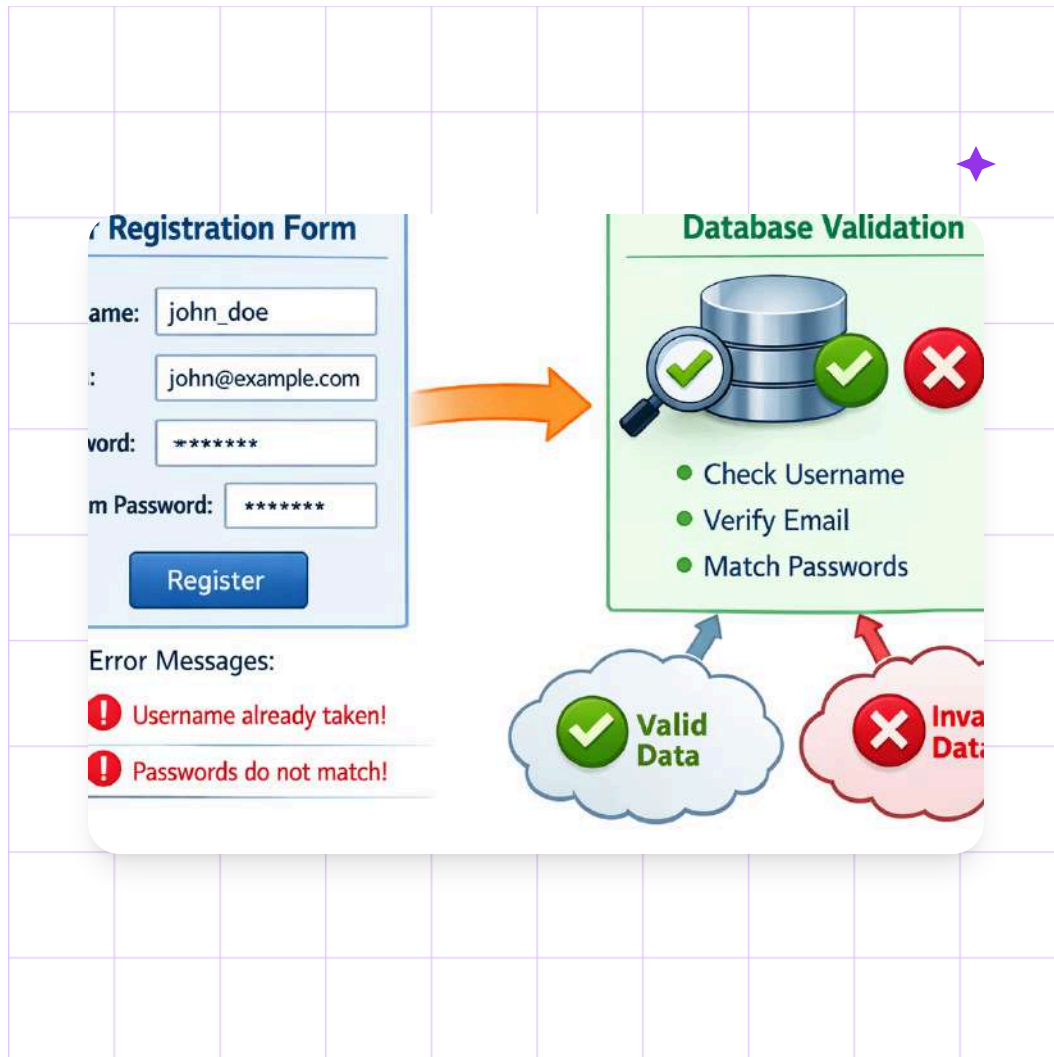
JWT dikirim lewat header Authorization saat mengakses endpoint terproteksi agar identitas pengguna dapat diverifikasi.

Struktur Data User

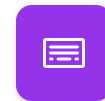
Field	Deskripsi
id	Identitas unik user
name	Nama user
email	Alamat email user
password_hash	Hasil hash password
role	Pembeda hak akses

Data user minimum mencakup identitas, informasi akun, hasil hash password, dan **role** untuk membedakan akses user dan admin.

Endpoint Register



Endpoint register menambahkan pengguna baru ke database dengan validasi email, password, dan keunikan akun.



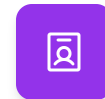
Input Data Pengguna

Data umum meliputi name, email, password, dan konfirmasi password bila diperlukan.



Validasi Email

Sistem memeriksa format email agar sesuai dan memastikan alamat dapat diterima.



Cek Keunikan Akun

Email harus belum terdaftar agar tidak digunakan oleh akun lain di database.

Proses Register yang Aman



01 Hash Password

Saat register, password di-hash sebelum disimpan agar kredensial asli tidak tersimpan di sistem.

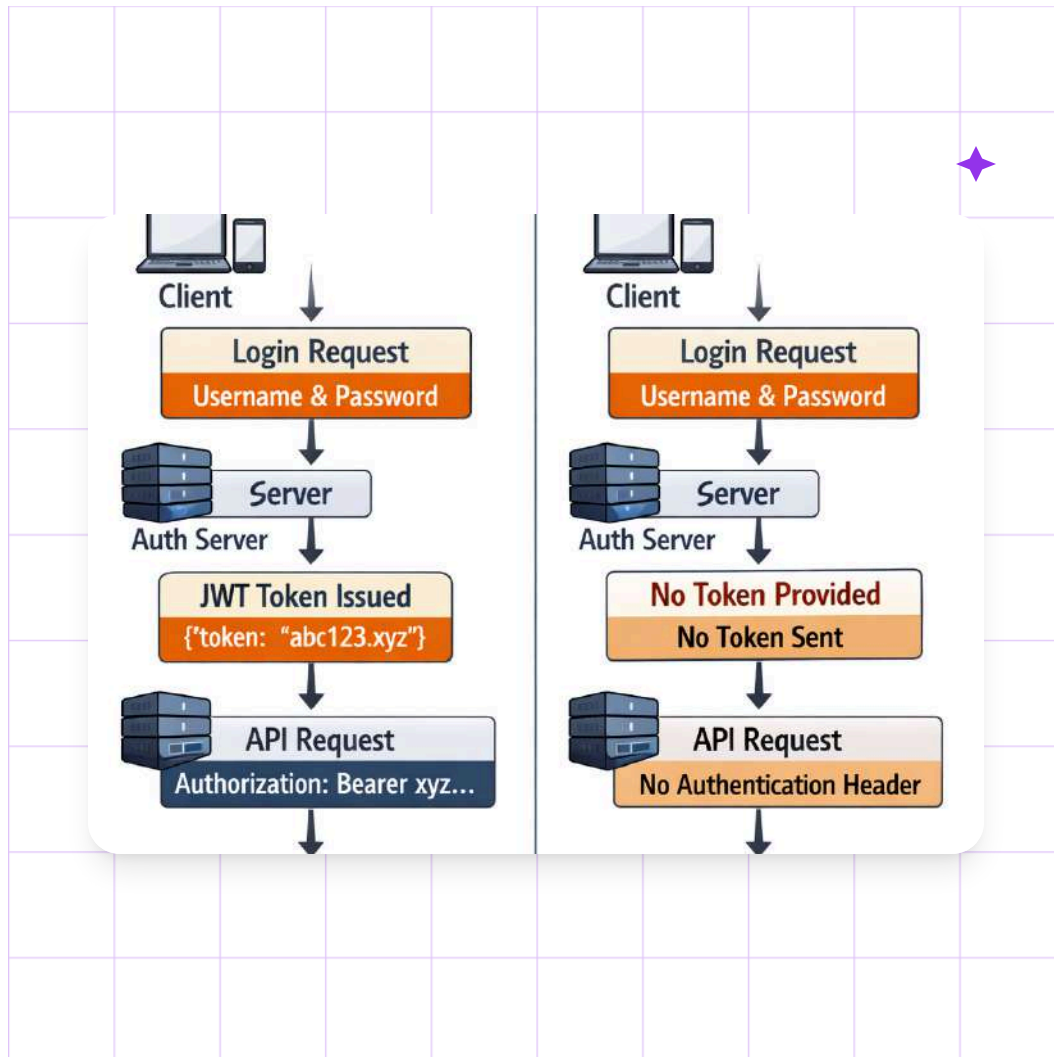
02 Buat User Baru

Setelah validasi berhasil, backend membuat record user baru dengan role default yaitu user.

03 Response Aman

Response tidak mengembalikan password hash untuk mencegah kebocoran data sensitif dan menjaga integritas akun.

Endpoint Login



Login menerima email dan password, memverifikasi kredensial, lalu membuat JWT jika valid.



Input Kredensial

Endpoint menerima email dan password dari pengguna untuk proses autentikasi.



Validasi User

Backend mencari user berdasarkan email dan mencocokkan password dengan hash tersimpan.



Hasil Autentikasi

Jika valid dibuat JWT berisi identitas dan role, jika gagal API mengembalikan respons autentikasi.



Konsep JWT pada Backend Gin

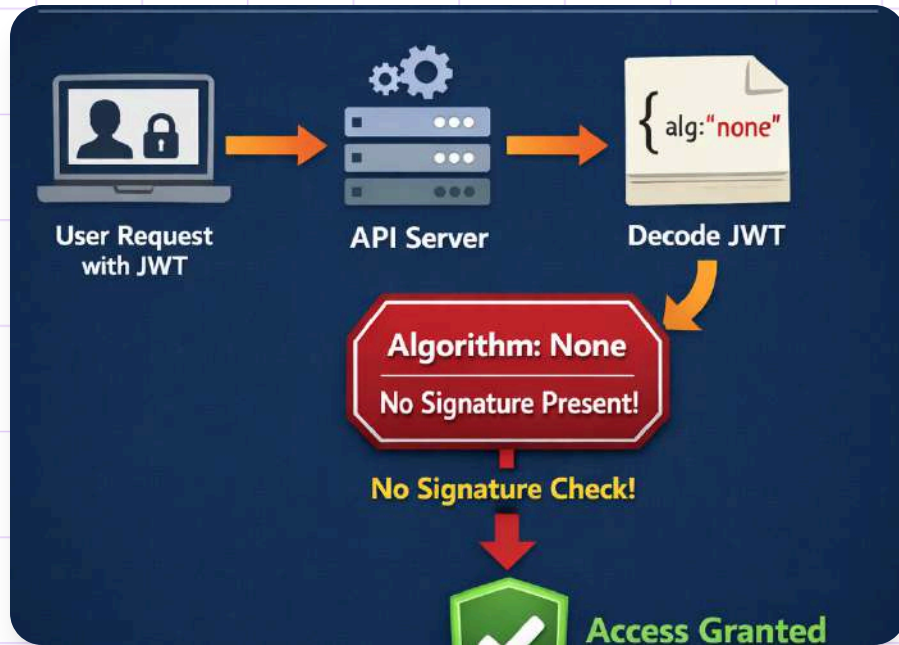
JWT membawa klaim identitas pengguna tanpa sesi server. Klaim umum: *user_id*, *email*, *role*, *issued_at*, dan *expired_at*.

Contoh Payload JWT

Field	Fungsi
user_id	Identitas pengguna
email	Alamat email pengguna
role	Hak akses atau otorisasi
iat	Waktu token diterbitkan
exp	Batas waktu berlaku token

Payload JWT memuat informasi identitas dan otorisasi. Backend wajib memverifikasi tanda tangan token serta memastikan token belum kedaluwarsa.

Middleware Auth JWT

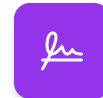


Middleware membaca header Bearer token, memverifikasi secret key, lalu menyimpan klaim user ke context jika valid.



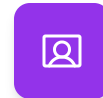
Baca Authorization Header

Middleware mengambil token dari header Authorization dengan format Bearer token.



Verifikasi Token JWT

Token diperiksa memakai secret key untuk memastikan validitas dan integritas klaim.



Simpan Klaim ke Context

Jika valid, klaim user disimpan ke context Gin; jika gagal, request ditolak unauthorized.

Otorisasi Role Admin dan User



Setelah autentikasi berhasil, sistem memeriksa role untuk menentukan izin akses pada setiap endpoint.



Akses Admin Terbatas

Endpoint tertentu hanya dapat diakses admin untuk menjaga kontrol pada fitur penting.



User Akses Umum

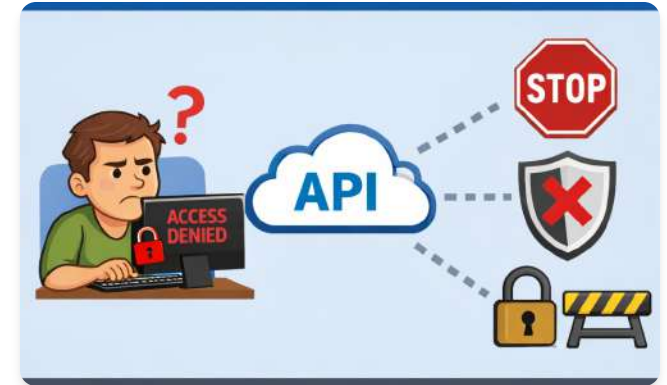
User biasa dapat memakai endpoint umum sesuai izin yang telah ditetapkan sistem.



Keamanan Lebih Baik

Pemisahan role membantu mengurangi risiko penyalahgunaan akses dan melindungi sistem.

Pembagian Endpoint per Role



01 Akses Bersama Setelah Login

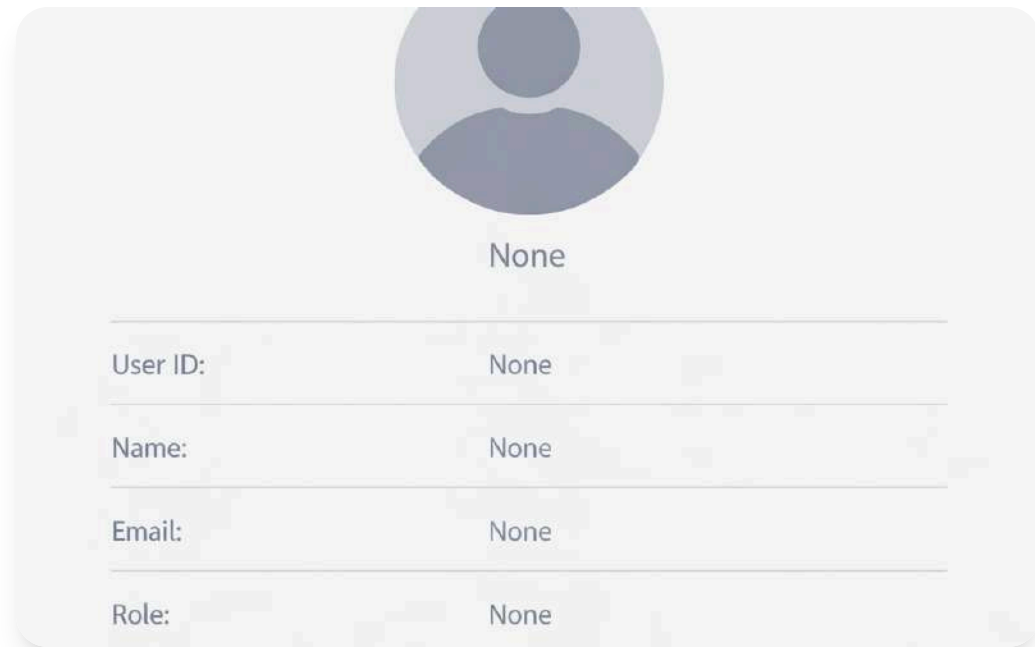
Endpoint *profile* dan *auth me* dapat diakses user maupun admin setelah JWT tervalidasi.

02 Endpoint Khusus Admin

Manajemen pengguna, penghapusan data, dan dashboard administratif hanya untuk admin.

03 Validasi via Middleware

Pemeriksaan role dilakukan melalui middleware khusus setelah token JWT selesai divalidasi.



Endpoint Auth Me

Endpoint ini mengambil data pengguna login dari token aktif untuk menampilkan profil, role, dan status autentikasi saat ini.

Logout dengan Blacklist Token



Pada JWT stateless, logout tidak langsung membatalkan token. Token logout disimpan di blacklist hingga kedaluwarsa.



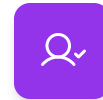
Token tidak otomatis batal

Pada JWT stateless, token yang sudah diterbitkan tetap valid meski pengguna logout.



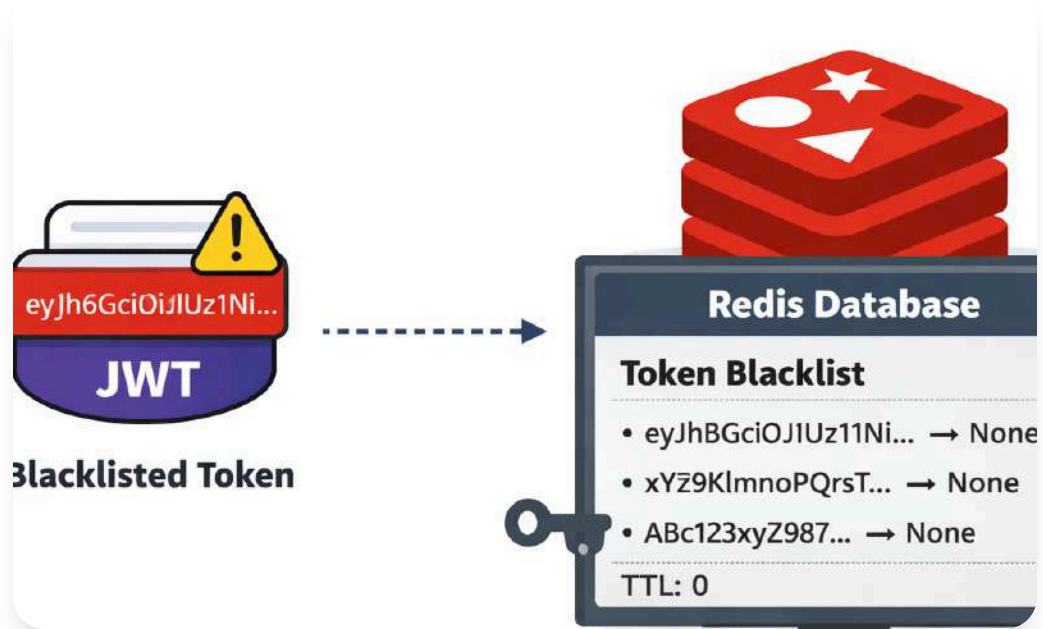
Blacklist sampai kedaluwarsa

Token hasil logout dimasukkan ke blacklist dan disimpan sampai masa berlakunya habis.



Dicek oleh middleware

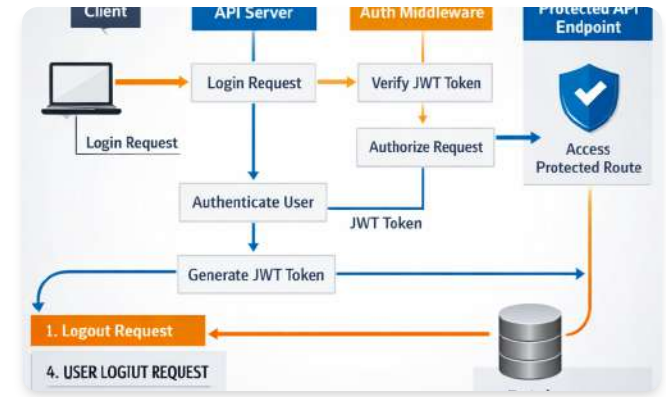
Saat validasi token, middleware juga memeriksa apakah token ada di daftar blacklist.



Implementasi Blacklist Token

Token blacklist disimpan di database atau Redis hingga masa exp berakhir agar token logout tidak dapat dipakai kembali.

Alur Request Login ke Logout



01 Register, Login, dan JWT

User melakukan register lalu login. Setelah berhasil, sistem mengirim JWT untuk dipakai pada request berikutnya.

02 Akses Endpoint Terproteksi

JWT digunakan untuk mengakses endpoint seperti auth me. Middleware memverifikasi token sekaligus role pengguna.

03 Logout dan Blacklist Token

Saat logout, token dimasukkan ke blacklist. Request berikutnya dengan token yang sama harus ditolak middleware.

Praktik Terbaik Keamanan Auth



Kredensial dan Token Aman

Gunakan password hashing yang kuat, secret key aman, dan masa berlaku token yang jelas.



Kontrol Akses dan Audit

Tambahkan blacklist, pembatasan akses berbasis role, serta audit log untuk login dan logout penting.

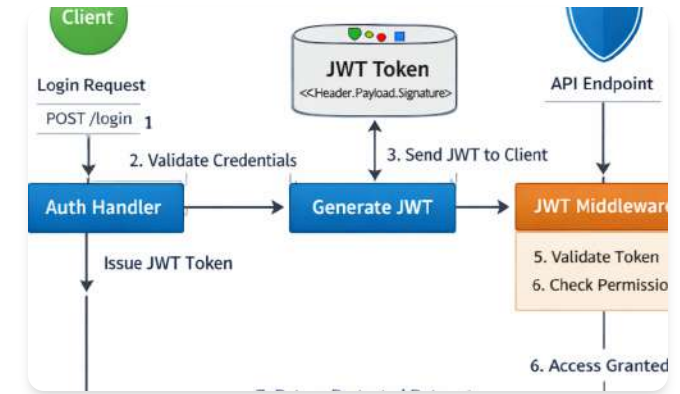


Validasi dan Error Terkendali

Terapkan validasi input ketat serta response error yang tidak membocorkan detail sensitif.



Latihan Praktik 1



01 Register API

Buat endpoint register dengan password yang disimpan dalam bentuk hash dan tetapkan role default sebagai user.

03 Middleware Auth

Buat middleware auth untuk melindungi endpoint GET /auth/me agar hanya dapat diakses dengan token yang valid.

02 Login dengan JWT

Buat endpoint login yang mengembalikan JWT berisi user_id dan role setelah kredensial berhasil diverifikasi.

Latihan Praktik 2

01 Middleware Role

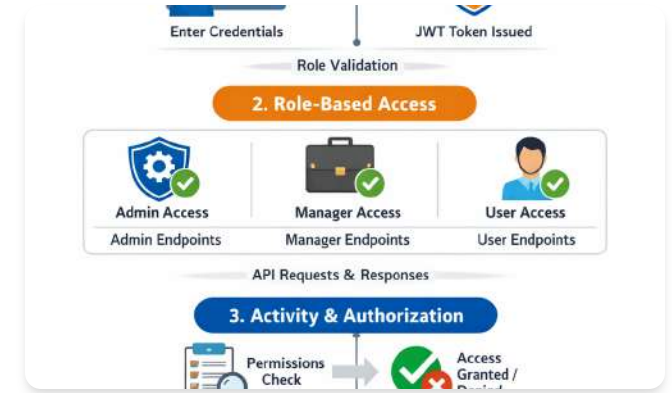
Buat middleware role untuk membedakan akses **admin** dan **user** pada setiap endpoint yang dilindungi.

03 Logout dan Blacklist

Implementasikan **POST /logout** untuk menyimpan token ke blacklist agar tidak bisa lagi dipakai ke **/auth/me**.

02 Admin Dashboard

Sediakan endpoint **GET /admin/dashboard** yang hanya bisa diakses oleh pengguna dengan role **admin**.



```
func register(c *gin.Context) {
    var user User
    (
    if err = c.ShouldBindJSON(&user); err != nil {
        c.JSON(http.StatusBadRequest, gin.H{"error: "Invalid input"})
    } return
    // Logic to save the user...
    c.JSON(http.StatusOK, gin.H{"message: "User registered"})
}
```

Ringkasan Pertemuan



"Fondasi auth backend modern di Gin: register aman, JWT, middleware, role, auth me, dan logout blacklist."

```
func login(c *gin.Context) {
    var user User
    (
    if err = c.ShouldBindJSON(&user); err != nil {
        c.JSON(http.StatusBadRequest, gin.H{"error: "Invalid credentials"})
    } return
    // Logic to authenticate the user...
    token = jwt.NewWithClaims(jwt.SigningMethodH256, jwt.MapClaims{
        "user_id!": user.ID,
        "exp!": time.Now().Add(time.Hour * 72).Unix());
    tokenString, __ := {
```

Ringkasan Materi